

CYROPAY LTD

Secure Development Policy

Document Information

Document ID	POL-008
Document Classification	Internal
Version	1.0
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Chief Executive Officer (CEO)
Effective Date	May 2026
Review Date	May 2027
Status	Approved

1. Purpose

This Secure Development Policy establishes the security requirements that must be embedded throughout CyroPay Ltd's software development lifecycle. As a payment fintech processing cardholder data, CyroPay must ensure that all applications and systems are designed, developed, and tested with security as a foundational requirement, not an afterthought.

The policy addresses gaps identified in CyroPay's ISO 27001:2022 gap assessment, where secure coding standards, mandatory security testing, and formal SDLC security checkpoints were found to be absent.

2. Scope

This policy applies to all software development activities at CyroPay including new application development, feature enhancements, bug fixes, infrastructure as code, API development, and any modifications to production systems. It applies to all CyroPay developers, engineers, and any contractors or third parties involved in development activities.

3. Definitions

Term	Definition
SDLC	Software Development Lifecycle — the structured process for planning, creating, testing, and deploying software
SAST	Static Application Security Testing — automated analysis of source code for security vulnerabilities
DAST	Dynamic Application Security Testing — security testing of running applications
Threat Modelling	The process of identifying potential security threats to a system during the design phase
OWASP Top 10	A standard awareness document listing the ten most critical web application security risks
Code Review	A systematic examination of source code by peers to identify defects and security issues

Penetration Testing	Authorised simulated attack on a system to identify exploitable vulnerabilities
CI/CD	Continuous Integration/Continuous Deployment — automated pipeline for building, testing, and deploying code

4. Roles and Responsibilities

4.1 CISO

- Own and maintain this policy
- Commission annual penetration tests and review findings
- Approve security exceptions in the development process

4.2 Head of Development

- Ensure all developers receive secure coding training
- Enforce mandatory code review and security testing requirements
- Integrate SAST and DAST tooling into the CI/CD pipeline
- Ensure threat modelling is conducted for all significant new features

4.3 All Developers

- Follow CyroPay's secure coding standards in all development work
- Participate in peer code review for all code changes
- Complete annual OWASP Top 10 training
- Report identified security vulnerabilities immediately to the Head of Development and CISO

4.4 IT Manager

- Maintain separation of development, test, and production environments
- Ensure production deployments follow the change management process

5. Policy Requirements

5.1 Secure Development Lifecycle

- Security must be considered at every stage of the SDLC — requirements, design, development, testing, and deployment
- All new features and applications must undergo a threat modelling exercise during the design phase before development begins
- Security requirements must be formally captured as a mandatory section in all product requirements documents
- No code may be deployed to production without completion of all security checkpoints defined in this policy

5.2 Secure Coding Standards

- All developers must follow the OWASP Secure Coding Practices as the baseline coding standard
- Code must be protected against the OWASP Top 10 vulnerabilities as a minimum requirement
- Input validation must be applied to all user-supplied data on both client and server sides
- Sensitive data including passwords, API keys, and tokens must never be hardcoded in source code or committed to version control
- All cryptographic implementations must follow the standards defined in the Cryptography Policy

5.3 Code Review

- All code changes must be reviewed by at least one peer developer before merging to any branch

- Code reviews must specifically check for security vulnerabilities including injection flaws, authentication issues, and sensitive data exposure
- No developer may approve their own code changes
- Critical system changes must be reviewed by the Head of Development before deployment to production

5.4 Security Testing

- SAST tooling must be integrated into the CI/CD pipeline and must run automatically on every code commit
- DAST scanning must be conducted against the test environment before every production release
- Critical or high severity findings from SAST or DAST must be remediated before deployment proceeds
- An independent penetration test must be commissioned annually covering all customer-facing applications and payment infrastructure
- Security acceptance criteria must be included in the definition of done for all development tasks

5.5 Dependency and Third-Party Component Management

- All third-party libraries and open source components must be tracked in a software bill of materials (SBOM)
- Dependencies must be scanned for known vulnerabilities using automated tooling integrated into the CI/CD pipeline
- Critical vulnerabilities in dependencies must be remediated within 72 hours of discovery

5.6 Test and Production Environment Separation

- Development, test, and production environments must remain strictly separated at all times
- Live production data must never be used in development or test environments
- Test data must be anonymised or synthetically generated before use in non-production environments
- Access to production environments is restricted to the IT Manager and designated operations staff only

5.7 Secrets Management

- All secrets including API keys, database credentials, and certificates must be stored in approved secrets management tooling and never in source code
- Secrets must be rotated on a scheduled basis and immediately upon suspected compromise
- Access to secrets must follow least-privilege principles and be reviewed quarterly

6. Compliance and Monitoring

Compliance with this policy shall be monitored through:

- Internal audits and policy reviews
- Risk assessments and vulnerability assessments
- Security monitoring activities
- Management review meetings

Violations of this policy may result in disciplinary action, termination of access privileges, or legal escalation where appropriate.

7. Exceptions

Any exception to this policy must:

- Be formally documented with a business justification
- Be risk assessed and approved by the CISO

- Include compensating controls where necessary
- Be reviewed periodically and include an expiration date if temporary

8. Related Documents

- POL-001 Information Security Policy
- POL-003 Access Control Policy
- POL-005 Incident Response Policy
- POL-006 Data Classification and Handling Policy
- POL-010 Vulnerability and Patch Management Policy

9. ISO 27001 Annex A Mapping

Annex A Control	Description
A.8.25	Secure development lifecycle
A.8.26	Application security requirements
A.8.27	Secure system architecture and engineering principles
A.8.28	Secure coding
A.8.29	Security testing in development and acceptance
A.8.31	Separation of development, test and production environments
A.8.33	Test information

10. Document Control

Version	Date	Author	Changes
1.0	May 2026	CyroPay GRC Team	Initial version